

Penetration Testing Report

Client: Mediroza General Hospital

Target: medirozahospital.com

Assessment Type: Authorized Black-Box Web Application Security Assessment

Assessment Period: September–October 2026

Prepared for: Network Walks Cybersecurity & Ethical Hacking Internship

1. Executive Summary

An authorized black-box penetration test was conducted against medirozahospital.com as part of the Network Walks cybersecurity internship.

The assessment focused on identifying weaknesses in the web application, authentication mechanisms, access controls, exposed files, and protection of sensitive information.

The assessment identified several security issues, including:

- SQL injection resulting in authentication bypass.
- Unauthorized access to the patient portal and laboratory report listings.
- Weak protection of password-protected PDF reports.
- Public exposure of a historical database backup.
- Exposure of employee salary and shareholder information within the backup.

The findings demonstrate weaknesses in input validation, authentication controls, file protection, and server configuration.

All testing was performed within the authorized laboratory scope.

2. Scope and Methodology

Scope

Target:

<https://medirozahospital.com>

Testing was limited to the authorized client server and the activities specified in the Network Walks laboratory exercise.

Methodology

The assessment followed a progressive approach:

1. Reconnaissance and information gathering
2. Web and directory discovery
3. Authentication testing
4. SQL injection testing

5. Authentication bypass validation
6. Protected document analysis
7. PDF password/encryption testing
8. Examination of previously discovered files and directories
9. Sensitive data exposure analysis
10. Evidence collection and documentation

Tools Used

- Kali Linux
- nslookup
- dig
- WhatWeb
- Wafw00f
- Nmap
- cURL
- Browser-based testing
- Network Walks Hash Calculator
- Network Walks Password Cracker
- John the Ripper
- Standard Linux utilities

Limitations

Testing was restricted to the authorized target and laboratory objectives.

The assessment did not include denial-of-service testing, social engineering, or activities outside the defined scope.

3. Findings and Proof of Exploitation

M1 — SQL Injection and Authentication Bypass

Testing of the patient portal login identified SQL injection behavior.

An initial SQL injection test produced a database syntax error, indicating that user input was being incorporated into a SQL query without adequate protection.

A subsequent authorized test resulted in a redirect to the patient portal:

HTTP/2 302

location: portal.php

Using the resulting session, access to the patient portal was confirmed.

The portal exposed three encrypted laboratory reports.

Impact

An attacker could potentially bypass authentication and access restricted patient resources.

Evidence

- SQL injection error screenshot
- Authentication bypass screenshot
- Patient portal access screenshot
- Laboratory report listing screenshot

M2 — Weak PDF Password Protection

Three encrypted laboratory PDF reports were obtained through the authorized patient portal access.

Password recovery testing was performed using authorized password-cracking tools and multiple wordlists.

The first two reports were successfully recovered using the available Network Walks password-cracking workflow.

The third report required additional testing because the initial Network Walks wordlist was limited.

Additional wordlists were tested, including:

- rockyou.txt
- fasttrack.txt
- Nmap-related password lists
- John the Ripper's password list

John the Ripper successfully recovered the password for the third report.

Impact

Weak passwords protecting sensitive PDF documents can allow unauthorized recovery of confidential information if an attacker obtains the encrypted files.

Evidence

- PDF hash screenshots
- Password recovery screenshots
- Recovered PDF evidence
- John the Ripper result screenshot

M3 — Exposed Database Backup and Sensitive Information

Analysis of previously discovered information identified the following entry in robots.txt:

Disallow: /old/

The /old/ directory exposed:

mediroza_db_backup_2019.sql

The database backup contained two relevant tables:

staff

shareholders

The staff table contained employee salary information through the:

monthly_salary_zar

field.

The shareholders table contained:

shareholder_name

share_percent

shares_held

share_class

This confirmed exposure of historical employee salary and shareholder ownership information.

Impact

The exposed backup could disclose sensitive HR, personal, financial and ownership information.

Evidence

- /old/ directory screenshot
- Database backup screenshot
- Employee salary screenshot
- Shareholder information screenshot

Sensitive personal information has been redacted from the public portfolio.

4. Risk Rating

The following ratings are based on the potential impact and exploitability demonstrated during the assessment.

Finding	Risk	Justification
---------	------	---------------

SQL Injection / Authentication Bypass	Critical	Authentication controls could be bypassed, providing access to restricted patient resources.
Sensitive PDF Access / Weak Password Protection	High	Obtained encrypted reports could be recovered when weak passwords were used.
Exposed Database Backup	Critical	A publicly accessible backup exposed sensitive employee and shareholder information.

The ratings reflect the demonstrated security impact within the authorized laboratory environment.

5. Recommendations and Remediation

SQL Injection / Authentication Bypass

- Use parameterized SQL queries/prepared statements.
- Never directly concatenate user input into SQL queries.
- Implement server-side input validation.
- Use secure authentication mechanisms.
- Return generic authentication errors rather than database errors.
- Conduct security testing after remediation.

PDF Password Protection

- Require strong, randomly generated passwords for sensitive documents.
- Avoid predictable passwords such as common words or simple patterns.
- Use appropriate encryption standards for confidential documents.
- Apply password policies based on sensitivity.
- Consider additional access controls around document downloads.

Exposed Database Backup

- Remove database backups from publicly accessible directories.
- Store backups outside the web root.
- Restrict access using filesystem and application controls.
- Encrypt sensitive backups.
- Remove unnecessary legacy directories such as /old/.
- Disable directory listing where it is not required.
- Regularly scan web servers for exposed .sql, .bak, .zip, and other backup files.

Sensitive Information Protection

- Minimize the amount of personal information stored and exposed.
- Restrict access to HR and shareholder information.
- Apply appropriate data retention policies.
- Regularly review production servers for accidental information disclosure.

6. Conclusion

The penetration test identified multiple security weaknesses affecting authentication, document protection, and server-side information exposure.

The most significant findings involved authentication bypass through SQL injection and the public exposure of a historical database backup containing sensitive employee and shareholder information.

Remediation should prioritize eliminating SQL injection, strengthening authentication and document protection, removing publicly accessible backups, and implementing regular security reviews of production files and directories.

All testing and evidence collection were conducted within the authorized Network Walks laboratory scope.

7. Evidence Summary

Evidence	Description
M1 screenshots	Reconnaissance, SQL injection, authentication bypass and portal access
M2 screenshots	PDF hashes, password recovery and recovered reports
M3 screenshots	Exposed backup, employee salary and shareholder information

Sensitive patient, employee, credential and financial information should be redacted before the report is shared publicly.